

MedSecure SAS

HealthTech · SaaS · Données de santé

Information Security Management System Scope

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review
May 2026	1.0	Junior Abakar	Initial Version — DRAFT	CISO	May 2026	Annual	May 2027

Disclaimer: This document is provided for informational and educational purposes only as part of a personal GRC portfolio project. While reasonable efforts have been made to ensure the accuracy of the information contained herein, it is not intended to be professional advice. We make no warranties or representations of any kind, express or implied, regarding the accuracy or completeness of the information provided. You should not rely on this document for any commercial decision-making. By using this document, you agree to hold us harmless from any and all damages or losses arising from your use of this document.

MedSecure SAS is an entirely fictional organisation — any resemblance to a real entity is coincidental.

Purpose

This document defines the scope of the Information Security Management System (ISMS) implemented by MedSecure SAS in alignment with ISO/IEC 27001:2022. It outlines the boundaries and applicability of the ISMS, considering the organisation's context, business objectives, and relevant requirements of interested parties.

The scope ensures that information security risks are effectively identified and managed within the defined environment, supporting MedSecure SAS's commitment to maintaining the confidentiality, integrity, and availability of information related to its Software-as-a-Service (SaaS) patient records management platform — which processes health data classified as a special category under GDPR Article 9.

Scope Statement

The ISMS covers the design, development, hosting and operation of MedSecure SAS's cloud-based SaaS patient records management platform. It includes all processes, personnel, systems, infrastructure, and information assets directly involved in delivering the service, including development environments, production systems hosted on AWS (eu-west-3 region), and supporting internal tools (Slack, Jira, GitHub, Google Workspace). The scope encompasses all 45 employees across the Paris headquarters, the Lyon office, and remote workers, as well as relevant third-party services and vendors supporting the operation and security of the platform.

Context of the Organisation

Internal Issues

Internal issues relevant to the ISMS include the following:

Internal Issue	Impact on the ISMS
Small team with limited dedicated security resources (45 employees, IT team of 6)	Security efforts must be prioritised and pragmatic — a risk-based approach is essential to allocate controls effectively.
7 employees working fully remote across multiple locations	Increased exposure on endpoints and remote access channels — reinforced controls required under Annex A.6.7 (teleworking) and A.8.1 (user endpoint devices).
Cloud-native SaaS architecture hosted on AWS (multi-tenant)	Data isolation between tenants must be enforced. Encryption in transit and at rest is mandatory. Shared Responsibility Model must be clearly documented.
Use of third-party SaaS tools (Slack, Jira, GitHub, Google Workspace)	Access control policies and data handling agreements must cover all third-party tools. Shadow IT risk must be assessed.
Initial security awareness gap identified among non-technical staff	A security awareness and training programme is required under Annex A.6.3 to reduce human risk vectors.

External Issues

Legal, Regulatory, and Contractual Obligations

MedSecure SAS operates in a heavily regulated environment. The following legal, regulatory, and contractual obligations are applicable to the current scope of the ISMS:

Obligation	Description	Impact on ISMS
GDPR — Article 9 (Special category data)	Health data processed by MedSecure is classified as a special category under GDPR, requiring enhanced protection, lawful basis, and Data Protection Impact Assessments (DPIA).	Controls: A.5.34 (privacy), A.5.35 (DPIA) — mandatory breach notification to CNIL within 72 hours.
HDS Certification (France)	French regulation requiring any organisation hosting health data on behalf of healthcare providers to hold HDS certification, governed by the Agence du Numérique en Santé (ANS).	Technical and organisational controls beyond ISO 27001 — prerequisite for signing contracts with public hospital groups.
NIS 2 Directive (EU 2022/2555)	EU directive transposed in France in 2024. MedSecure may fall within scope as a digital service provider in the health sector — mandatory incident reporting obligations apply.	Incident reporting procedures must align with NIS 2 timelines — reinforces Annex A.5.24 to A.5.28.
Contractual — Hospital group requirement	The hospital group tendering process explicitly requires ISO 27001:2022 and HDS certification as a precondition for contract signature (2M€ contract).	Primary driver for ISMS implementation — defines the 6-month certification deadline.

Interested Stakeholders

The following stakeholders have been identified as having relevant interests or requirements that must be considered within the scope of the ISMS:

Stakeholder	Requirements
Chief Executive Officer (CEO)	Provides strategic leadership and ensures the ISMS supports business objectives. Primary accountable for obtaining ISO 27001 and HDS certifications within 6 months to secure the 2M€ hospital contract.
Information Security Manager (CISO)	Leads ISMS implementation and maintenance. Responsible for risk management, policy development, coordination of internal audits and management reviews, and liaison with certification body.
Cyber Security GRC Analyst	Manages governance, risk and compliance processes. Handles policy development, risk assessments, control mapping to ISO 27001 Annex A, and Statement of Applicability (SoA) maintenance.

IT Infrastructure Engineer	Manages AWS cloud infrastructure, network configuration, access controls, and supports system availability and integrity. Responsible for implementing technical controls under the ISMS.
Software Development Team	Develops and maintains the SaaS platform. Must integrate secure development practices (Annex A.8.25 to A.8.34) — secure coding, vulnerability management, and change management.
All Employees (45 staff)	Required to comply with MedSecure's information security policies and complete mandatory security awareness training. Remote employees must follow additional teleworking security procedures.
Amazon Web Services (AWS)	Cloud service provider hosting the SaaS platform (eu-west-3). Responsible for physical and infrastructure-level security under the Shared Responsibility Model. AWS holds ISO 27001 and SOC 2 certifications — MedSecure is responsible for securing configurations, access, data and applications.
Hospital group clients	Expect secure, reliable access to the SaaS platform. Require ISO 27001 and HDS certification for procurement. Rely on service availability, health data integrity, and protection from unauthorised access or disclosure.
CNIL (French Data Protection Authority)	Regulates GDPR compliance in France. Requires maintenance of a record of processing activities, DPIA for health data processing, and breach notification within 72 hours of detection.
ANS (Agence du Numérique en Santé)	Governs HDS certification in France. Requires MedSecure to demonstrate technical and organisational security measures for hosting health data on behalf of healthcare providers.

Document Approval

Role	Name	Date	Signature
Author	Junior Abakar — GRC Consultant	May 2026	
Reviewer	CISO — MedSecure SAS	TBD	
Approver	CEO — MedSecure SAS	TBD	

SMSI-MDS-C4-001 · Version 1.0 DRAFT · May 2026 · CONFIDENTIAL